CI/CD Pipeline Reference

Document ID	ENG-007
Department	Engineering
Document type	Reference
Owner	Director of Platform Engineering
Version	4.3
Status	APPROVED
Effective / last reviewed	2025-08-15
Audience	Engineering staff
Related documents	ENG-003, ENG-006, ENG-008, SEC-007

Summary. Reference for the NorthShip CI/CD platform used by Northstar engineering. Describes pipeline stages, quality and security gates, artefact handling, environments, promotion, rollback automation, secrets, runners, failure handling and pipeline change control.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This reference describes how the NorthShip CI/CD pipeline platform builds, tests, scans, packages, promotes and deploys software at Northstar Systems Private Limited. It documents the standard stages every pipeline must have, the gates that block a change, how artefacts and secrets are handled, how promotion to production works and what to do when a pipeline fails. It applies to all repositories for the Northstar Nexus Platform, Nexus Connect, Nexus Insight and internal services, and to engineers, release managers, SRE, Security Champions and QA staff who build or maintain pipelines.

Branching and release rules are in ENG-006. Deployment procedure and rollback runbook are in ENG-003. Testing strategy and coverage thresholds are in ENG-008. Code review rules are in ENG-001, and open-source and dependency rules are in ENG-015 and SEC-007. This document is a reference: it states what the pipeline enforces and how to read its results, and it is the first place to look when a pipeline stage blocks a merge or a release.

2. Definitions

- **NorthShip**: the CI/CD platform that runs pipelines, stores build artefacts and records deployments.
- **Pipeline**: the automated sequence of stages defined in a repository's pipeline file.
- **Stage**: a group of jobs, such as build or test. A stage must pass before the next stage runs.
- **Gate**: a pass or fail rule that stops promotion. Gates are enforced by the platform and cannot be skipped by developers.
- **Artefact**: a build output such as a container image, package or installer, immutable once published.
- **SBOM**: Software Bill of Materials, a list of all components in an artefact, generated for every release.
- **Runner**: the machine or container that executes pipeline jobs.

- **Environment**: a named target for deployments: development, test, staging and production.
- **Promotion**: moving the same artefact from one environment to the next without rebuilding.
- **Canary**: a staged production rollout beginning with a small share of traffic.
- **Provenance**: a signed record of which commit, builder and inputs produced an artefact.

3. Roles and Responsibilities

Role	Responsibilities
Developer	Keeps the pipeline file in their repository valid, fixes failures promptly, never bypasses gates
Platform Engineering	Owns NorthShip, runner images, shared pipeline templates and this reference
Release manager	Triggers promotions on the release train per ENG-006, verifies gates and rollout
Security Champion	Reviews pipeline security changes, scanner policies and exceptions
SRE	Owns rollout automation, rollback triggers and production deployment health checks
QA Lead	Owns test gates, test environment data and flaky test management
CISO delegate	Approves risk acceptance for time-limited vulnerability exceptions

4. Pipeline Stages

Every pipeline created from the Platform Engineering template contains the stages below, in this order. Teams may add stages but must not remove or reorder mandatory ones.

Stage	Purpose	Gate that blocks
1. Validate	Lint, format check, commit message check, pipeline file schema	Any lint error
2. Build	Compile and package into an immutable artefact with a version stamp	Build failure
3. Unit test	Run unit tests, collect coverage	Test failure or new-code coverage below 80%
4. Security scan	Static analysis, dependency scan, licence scan, secret scan	Findings above policy (section 6)
5. Integration test	Smoke and integration tests in the test environment	Any smoke failure
6. Package and sign	Create SBOM, sign artefact, record provenance	Missing SBOM or signature
7. Deploy to staging	Deploy artefact and run staging checks	Health check failure
8. Performance test	Run for major releases and performance-sensitive changes	Regression beyond agreed budget
9. Approval	Verify change ticket and approvals	No NorthDesk change ticket
10. Production rollout	Canary, then staged promotion	Rollback triggers (section 8)

4.1 Stage details

Validate. Linting runs on every push to a branch and on every PR. Commit messages must follow the form `<ticket>: <summary>` from ENG-006.

Build. Builds must be reproducible: the same commit and the same builder image produce the same artefact. The build runs in a clean runner with pinned dependency versions and no network access except to the approved internal artefact proxy.

Unit test. New code coverage must be at least 80%, in line with ENG-008. Coverage is computed on lines changed in the PR, so old low-coverage code does not block unrelated changes. Flaky tests identified by the retry detector are reported to the QA Lead and must be quarantined within 2 business days.

Security scan. See section 6.

Integration test. Release gating relies on integration smoke tests. The test environment is seeded with synthetic data only and never contains customer production data.

Package and sign. The artefact is signed with a key held in the cloud KMS and the signature and SBOM are stored with it. Production deployment accepts only artefacts that carry a valid signature and trace to a signed Git tag as described in ENG-006.

Approval. The platform checks that a NorthDesk change ticket exists for the production change, with a rollback plan, and that a Normal change has CAB approval. For Emergency changes it checks for approval by the Engineering Director on call. A change ticket is mandatory for every production change.

5. Environments and Promotion

5.1 Environment model

Environment	Purpose	Data
Development	Developer experiments and PR previews	Synthetic
Test	Integration tests, automatic on merge to `main`	Synthetic
Staging	Production-like validation and performance tests	Anonymised or synthetic
Production	Customer traffic in the Mumbai primary region, with the Hyderabad secondary region for DR	Real

Customer production data (classified Restricted) must never be copied to development, test or staging. If anonymised data is required, it must be produced by the approved masking job and approved by the data owner.

5.2 Promote, do not rebuild

The artefact built once at stage 2 is the artefact that moves to every environment. Rebuilding for production is not allowed, because it breaks traceability. Configuration differences between environments are supplied as environment variables or configuration files managed in version control, and secrets are injected at deploy time.

5.3 Deployment window

Production promotions follow the deployment window in ENG-006: Tuesday to Thursday, 10:00 to 16:00 IST. The platform blocks production promotion outside this window, on Fridays and on Monday mornings, and during quarter-end and company-declared freeze periods. The only way to deploy outside the window is an Emergency change flagged in the NorthDesk ticket and approved

by the Engineering Director on call; the platform checks this flag.

6. Security and Quality Gates

6.1 Scans

- **Static analysis** runs on every PR. High-severity findings block the merge.
- **Dependency scan** compares dependencies with vulnerability databases. A new dependency with an unpatched critical vulnerability must not be added. Existing dependencies are remediated within the vulnerability SLAs: Critical (CVSS 9.0 to 10.0) within 72 hours, High (7.0 to 8.9) within 14 days, Medium (4.0 to 6.9) within 30 days and Low within 90 days.
- **Licence scan** checks that dependencies use allowed licences. MIT, Apache-2.0, BSD-2-Clause, BSD-3-Clause and ISC are allowed. LGPL, MPL-2.0 and EPL need Open Source Review Board approval. AGPL, SSPL, GPL in distributed products and any licence without clear terms are prohibited and block the build. See ENG-015.
- **Secret scan** looks for keys, tokens and credentials in the diff and the history. Any finding blocks the PR; the secret must be revoked and rotated and the Security Desk informed.
- **Container and infrastructure scan** checks base images and infrastructure definitions for misconfiguration, such as public storage or missing encryption.

6.2 Vulnerability exceptions

If a vulnerability cannot be fixed in time, the owning team must request a risk acceptance. The CISO delegate may grant it for a maximum of 90 days with an expiry date and compensating controls, recorded in NorthDesk. The pipeline reads the exception register and stops ignoring a finding when its exception expires.

6.3 SBOM

An SBOM is generated for every release and attached to the artefact. Customer Success and Legal can request an SBOM for a given version from Platform Engineering through NorthDesk.

6.4 Quality gates on pull requests

A PR needs a green pipeline, the required number of approvals (2 for Tier-1 services, 1 for others) and a different approver from the author, as set out in ENG-001. Reviewers must not approve a PR whose gates have been overridden. Platform Engineering does not provide a gate-skip option; the only route to a different result is to fix the cause or file an exception through the Director of Platform Engineering.

7. Artefacts and Retention

- Artefacts are immutable. Once published with a version, they cannot be overwritten; a new version is required.
- Artefacts are stored in the internal artefact repository, replicated to the secondary region in Hyderabad and encrypted at rest with AES-256.
- Release artefacts are retained for the support period of the version. Pipeline build logs are retained for 12 months, in line with the application log retention schedule, and artefacts from PR builds are deleted after 30 days.
- Artefact signatures and the SBOM must be verifiable by the production deployer. A failed verification blocks deployment and raises a SEV3 ticket for Platform Engineering.
- Only NorthShip may publish to production repositories. Developers cannot push artefacts manually.

8. Rollout Automation and Rollback

Production rollout is performed by NorthShip in stages: canary 10% for 30 minutes, then 50% for 30 minutes, then 100%. At each stage the platform compares the canary's error rate and latency with the baseline from NorthWatch.

The automatic rollback trigger is an error rate above 2% or p95 latency above 1.5x baseline for 5 consecutive minutes. When triggered, the platform stops the rollout, reverts to the previous artefact and posts a notification to the release channel and the on-call engineer. A rollback must complete within 15 minutes of the decision. A manual rollback may be started by the release manager or the on-call engineer at any time, without waiting for approval, and a rollback decision never needs CAB review.

Example: At 10:20 IST the release manager starts the canary of a new Pipeline scheduler version. At 10:35 the canary's error rate rises to 3.4% and stays there for 5 consecutive minutes. NorthShip triggers automatic rollback at 10:40, and the previous artefact is serving all traffic by 10:50, within 15 minutes. A NorthDesk problem ticket is opened automatically.

After a rollback, the same version cannot be redeployed. A corrected build with a new version number is required.

8.1 Database coordination

Database migrations are deployed in the same window as the code, following ENG-009. Because code can be rolled back but destructive migrations cannot, the pipeline blocks a release that contains a destructive schema change together with the code that stops using the old structure.

9. Secrets and Access in Pipelines

- No secrets are stored in source code or pipeline files. Secrets live in NorthVault or a KMS-backed secret store and are injected at runtime with short-lived tokens.
- Service account credentials used by pipelines are rotated every 90 days.
- Pipeline service accounts use least privilege and have separate identities per environment. A production deployment identity cannot be used from a development pipeline.
- Developers do not have direct production credentials. Production administration is done only through the NorthGate bastion with session recording, and just-in-time privileged access lasts at most 8 hours.
- Changes to pipeline definitions of Tier-1 services need review by a Platform Engineering member and by a Security Champion when they affect scanning, signing or deployment stages.
- Runner logs must not echo secrets; the platform masks values known to be secrets, and a leaked secret in a log is treated as a secret exposure incident.

10. Runners and Capacity

Runners are ephemeral containers created per job and destroyed after it ends. Self-hosted runners use hardened images patched at least within 14 days of release of the operating system patch. Jobs have a default timeout of 30 minutes and a maximum of 120 minutes, with exceptions needing Platform Engineering approval. Builds for different tenants of the platform are isolated. Queue time is monitored; if the 90th percentile queue time exceeds 10 minutes for 3 consecutive business days, Platform Engineering adds capacity.

11. Handling Failures

11.1 Failing pipeline checklist

1 Read the first failing stage in NorthShip; later failures are often side effects.
2 Check whether `main` itself is red. If it is, the owning team must fix or revert within 2 hours during business hours, and merges to the repository are paused until `main` is green.
3 For a flaky test, retry once, report it to the QA Lead and quarantine it within 2 business days.
4 For an infrastructure error such as a runner crash, retry and raise a NorthDesk ticket with the job ID if it repeats.
5 For a security finding, follow section 6 and never remove the scanner.

11.2 Quarantine rules for flaky tests

A flaky test is one that fails and then passes on the same commit. Quarantined tests move to a separate non-blocking job, are tracked in NorthDesk with an owner and must be fixed or deleted within 30 days. A repository with more than 5 quarantined tests must have a stabilisation plan reviewed by the QA Lead.

11.3 Production deployment failures

If a deployment stops halfway because of a platform failure, the release manager must leave the environment in a known state: either completed or rolled back. Mixed versions across regions must not be left for more than 30 minutes without an incident being declared under ENG-004.

12. Changing Pipelines and NorthShip

Changes to shared templates and the NorthShip platform are Normal changes and need CAB approval. Teams that want to modify their pipeline file may do so through a reviewed PR but must keep all mandatory stages. Platform Engineering publishes template versions with semantic versioning, announces breaking changes at least 4 weeks ahead and supports the previous template major version for 6 months. Any attempt to disable a gate, whether in the pipeline file or in platform configuration, is reported to the Security Desk.

13. Frequently Asked Questions

Can I skip the security scan for an urgent fix? No. Emergency changes still run the scan. If a finding blocks an urgent fix, the Security Champion may recommend a time-limited exception to the CISO delegate.

Why did my deployment start but stay at 10%? NorthShip holds each canary stage for 30 minutes and checks the metrics. Wait until the stage completes or investigate whether the metrics are deteriorating.

Why is there a block on Friday? Friday and Monday-morning production deployments are blocked, except emergency changes, as described in ENG-006.

Where do I get the SBOM for a release? It is attached to the release artefact in NorthShip.

14. Related Documents

- ENG-003 Software Deployment Runbook: deployment and rollback procedure.
- ENG-006 Branching and Release Management Standard: tags, release train and freezes.

- ENG-008 Testing and QA Standards: coverage and test pyramid.
- ENG-015 Open-Source and Third-Party Library Usage Policy: licences.
- SEC-007 Secure Development Standard: secure coding and scanning expectations.
- ENG-009 Database Change Management Procedure: migrations.

15. Revision History

Version	Date	Change
4.0	2025-02-11	Added mandatory signing and provenance stage
4.2	2025-05-27	Introduced exception register integration for scanners
4.3	2025-08-15	Clarified rollout stages and runner timeouts